FIELD STUDY & CERTIFICATION GUIDE

Wireless Security: Attacks, Tools and Defenses

A technical reference covering 802.11 mechanics, active exploitation workflows, Bluetooth attack surfaces, and defensive monitoring controls.

Domain	Offensive Wireless & RF Security
Protocols	802.11a/b/g/n/ac/ax, WPA2/WPA3, Bluetooth
Focus	Discovery, Exploitation, Handshake Cracking, WIPS
Audience	Security Practitioners & CEH Candidates



Wireless Concepts: how WLANs work

Wireless Local Area Networks rely on unbounded radio frequencies to transport 802.11 frames between transceivers, eliminating physical perimeter boundaries.

CORE COMPONENTS

APs, Stations, and Addressing

Access Points (APs) bridge RF frames to wired Ethernet. Client stations (STAs) associate via Service Set Identifiers (SSID), while the Basic Service Set Identifier (BSSID) binds to the AP radio MAC address. Spectrum spans 2.4 GHz (14 channels), 5 GHz (UNII-1 through UNII-3), and 6 GHz (Wi-Fi 6E/7) across 20 to 160 MHz swaths.

PHYSICAL & MAC EVOLUTION

802.11 Protocol Standards

802.11b introduced 11 Mbps via DSSS in 2.4 GHz. 802.11a/g established 54 Mbps OFDM across 5 GHz and 2.4 GHz bands. 802.11n (Wi-Fi 4) added MIMO and 40 MHz channels up to 600 Mbps. 802.11ac (Wi-Fi 5) delivered multi-gigabit 5 GHz throughput via 256-QAM, while 802.11ax (Wi-Fi 6) introduced OFDMA resource units and MU-MIMO for congested cells.

DEPLOYMENT TOPOLOGIES

Infrastructure vs. Ad Hoc

Infrastructure mode routes all station communication through a central AP to an Extended Service Set (ESS) on the Distribution System. Independent Basic Service Sets (IBSS) or ad hoc topologies link peer stations directly without infrastructure, exposing endpoints to unmonitored lateral compromise.

ACCESS CONTROL

Authentication Modes

Open System authentication provides null authentication followed by optional upper-layer association. Shared Key authentication proves possession of a static key via flawed WEP challenge text. Centralized enterprise models employ 802.1X Extensible Authentication Protocol (EAP) coupled to RADIUS servers.

Wireless Concepts: antennas, devices and terms

RF propagation does not stop at drywall or corporate window glass. Radio range and radiation patterns dictate the perimeter an attacker must occupy.

01 Omnidirectional Dipoles

Radiate in a 360-degree toroidal donut. Standard 2 dBi to 9 dBi rubber duck antennas deploy on client cards and ceiling APs, creating wide, uniform coverage footprints.

02 Directional Yagi and Parabolic Grids

Focus RF power into narrow high-gain beams (15 dBi to 24 dBi). Directional grids enable wardrivers and auditors to intercept frames and inject packets from over a kilometer away.

03 Spread Spectrum Mechanics

DSSS combines data with a high-rate chipping code (Barker sequence). OFDM splits wide carrier channels into orthogonal subcarriers. FHSS hops pseudorandomly across frequency channels.

04 ISM Spectrum & Boundary Leakage

Industrial, Scientific, and Medical (ISM) 2.4 GHz bands suffer heavy attenuation from concrete, yet sidelobes leak into perimeter parking lots and street-level access corridors.

FIELD EQUIPMENT / HARDWARE SPEC

Primary Standard

IEEE 802.11-2020

ISM Allocations

2.400–2.4835 GHz / 5.150–5.850 GHz

Antenna Connector

RP-SMA / N-Type Coaxial



Long-range directional hardware mounted for RF inspection

CRYPTOGRAPHIC TIMELINE

Wireless Encryption: from WEP to WPA3

Flaws in key scheduling and frame encapsulation forced the IEEE from insecure stream ciphers to robust authenticated encryption modes.

PROTOCOL	CIPHER	INTEGRITY	STATUS
WEP	RC4	CRC-32	Broken
WPA	RC4 + TKIP	MIC	Deprecated
WPA2	AES-CCMP	CCM MAC	Common, KRACK-exposed
WPA3	AES-CCMP/GCMP	AEAD	Current

WEP IV Exhaustion

A 24-bit Initialization Vector generates only 16,777,216 unique key streams. On busy links, IV collisions occur inside 5 hours without attack stimulation, enabling bit-flipping attacks against CRC-32.

WPA3 SAE Resistance

Simultaneous Authentication of Equals executes a zero-knowledge password-authenticated key exchange. Eavesdroppers intercepting the exchange gain zero capability to verify password guesses offline.

Wireless Encryption: authentication and key handling

WPA and WPA2 rely on a master key hierarchy to generate dynamic transient session keys. Flaws in nonce exchange open personal configurations to dictionary attacks.

KEY HIERARCHY

PMK, PTK and GTK Derivation

The Pairwise Master Key (PMK) is derived from the passphrase via PBKDF2 (4,096 HMAC-SHA1 iterations) or supplied by a RADIUS server. During the 4-way handshake, the AP (Authenticator) and station (Supplicant) combine the PMK, AP MAC, Client MAC, ANonce, and SNonce to construct the Pairwise Transient Key (PTK).

- **KCK (Key Confirmation Key):** Verifies data origin authenticity and calculates HMAC-SHA1 MICs.
- **KEK (Key Encryption Key):** Encrypts the Group Transient Key (GTK) delivered to stations for broadcast.
- **TK (Temporal Key):** 128-bit key used directly by CCMP to encrypt unicast payload data frames.

ENTERPRISE METHODS

802.1X EAP Authentication Variants

Enterprise deployments pass EAP over LAN (EAPoL) frames to an authentication server, providing dynamic per-user PMK generation without shared static secrets.

- **EAP-TLS:** Mutual certificate validation; strongest posture, requires enterprise PKI deployment.
- **PEAP (MS-CHAPv2):** Server certificate establishes TLS tunnel; inner MS-CHAPv2 credential susceptible to rogue AP relay.
- **LEAP:** Cisco legacy protocol; transmits MS-CHAP challenge responses unencrypted, easily cracked with asleap.

> ### The 4-Way Handshake Vulnerability
>
> Message 1 transmits the ANonce plaintext. Message 2 replies with SNonce and an EAPoL MIC. Attackers sniffing Messages 1 and 2 possess all variables required to execute offline dictionary and brute-force attacks against the PMK without sending further frames to the target network.

Wireless Threats: the attack landscape

CATEGORY 01

Access Control Attacks

- Rogue APs
- MAC spoofing
- Ad hoc connections

CATEGORY 02

Confidentiality Attacks

- Eavesdropping
- Traffic analysis
- Evil twin

CATEGORY 03

Integrity Attacks

- Frame injection
- Replay
- Data tampering

CATEGORY 04

Availability Attacks

- Deauthentication floods
- RF jamming
- Beacon flooding

CLIENT LURING & MISASSOCIATION

Wireless Threats: rogue APs and evil twins

Stations constantly search for known networks, making association decisions based entirely on SSID strings and relative signal strength indicators (RSSI).

01 The Evil Twin Signal Race

An attacker broadcasts an identical ESSID on an adjacent channel with higher transmit power. Wireless client roaming algorithms automatically sever clean AP connections to re-associate with the stronger malicious beacon.

02 Preferred Network List (PNL) Exploitation

Client devices broadcast directed probe requests containing SSIDs of previously joined networks. Rogue frameworks capture these probe names and instantiate matching networks on the fly (the classic KARMA attack technique).

03 Captive Portal Credential Phishing

Once associated, the rogue AP routes all HTTP/DNS requests to an internal web server displaying a simulated firmware update or corporate WPA2 passphrase entry portal.

04 Reconnaissance: Wardriving & Warchalking

Attackers map geographical enterprise boundaries by correlating GPS coordinates with detected BSSIDs, signal power, and encryption ciphers.

ATTACK HARDWARE & DEPLOYMENT

Attack Platform

WiFi Pineapple / Hostapd-Mana

Lure Method

Probe Response Spoofing (MANA)

Credential Capture

DNS Spoof + Rogue Captive Portal



Covert dual-band rogue access device deployed for credential harvesting

Hacking Methodology: discover and map

Structured wireless penetration testing begins with non-intrusive spectrum reconnaissance, identifying target infrastructure and client behaviors without alert generation.

01 / Passive Scan

Place wireless interfaces into monitor mode (rfmon) to capture raw 802.11 beacon frames across all channels without transmitting probes.

02 / Active Probing

Transmit broadcast probe requests to uncloak hidden SSIDs and force sleeping client devices to reveal Preferred Network Lists.

03 / GPS Geolocation

Correlate intercepted frame signal strength (RSSI) with real-time NMEA GPS data to triangulate physical AP and client locations.

04 / Traffic Dissection

Filter captured pcap files in Wireshark for EAPoL exchanges, probe requests, and connected station MAC addresses per BSSID.

Passive Discovery Attributes

Listening on 2.4 GHz and 5 GHz channels without associating leaves zero trace in enterprise Wireless Intrusion Detection Systems (WIDS). Observers harvest beacon intervals, capability information elements, supported data rates, and manufacturer OUIs directly from frame headers.

Uncloaking Hidden SSIDs

Suppressing the SSID in AP beacon frames does not secure the network. When legitimate clients connect, probe requests and association request frames transmit the SSID string in cleartext, immediately exposing the hidden network to any active sniffer.

ACTIVE EXPLOITATION & KEY RECOVERY

Hacking Methodology: attack and crack

Once target networks and client relationships are mapped, penetration testers execute active injection to harvest keys, crack hashes, and pivot internally.

01 / Force Handshake

Inject spoofed deauthentication frames to disconnect a target station, capturing the 4-way handshake upon automatic reconnection.

02 / Cryptanalysis

Convert captured EAPoL frames to 22000 format and execute dictionary, rule-based, or mask attacks using hashcat or Aircrack-ng.

03 / WPS Compromise

Audit legacy Wi-Fi Protected Setup using Pixie Dust or offline PIN brute-forcing against half-PIN validation vulnerabilities.

04 / Lateral Pivot

Authenticate with cracked credentials, bypass internal network isolation, scan internal subnets, and compromise corporate targets.

TECHNIQUE	TARGET	EXPLOITATION MECHANISM
Deauth Injection	Client STA & AP BSSID	Sends unencrypted IEEE 802.11 deauth frames (Reason Code 7) to sever active associations.
WPS Pixie Dust	WPS Enrollee Access Points	Exploits weak pseudorandom number generators in E-S1 and E-S2 nonces to recover WPS PINs in seconds.
ARP Amplification	WEP Access Points	Replays intercepted ARP request packets thousands of times per second to force generation of fresh IVs.

Wireless Hacking Tools: discovery and sniffing

Effective wireless auditing requires specialized packet injection drivers, radio frequency monitors, and signal analysis software.

LAYER 2 RF MONITOR

Kismet

The industry-standard passive wireless sniffer. Operates silently without transmitting RF energy, detecting hidden SSIDs, mapping network traffic relationships, and logging GPS coordinates to SQLite databases. Supports 802.11a/b/g/n/ac/ax, Bluetooth, and SDR inputs.

PACKET DISSECTION

Wireshark & AirPcap

Wireshark captures raw 802.11 frames when paired with monitor-mode interfaces, parsing Radiotap headers, signal strength (dBm), channel frequencies, and frame subtypes. Supports real-time WPA2 decryption once the PSK and 4-way handshake are provided.

ACTIVE DISCOVERY SCANNERS

NetStumbler & inSSIDer

NetStumbler pioneered early active probing on legacy Windows platforms. Modern survey suites like inSSIDer and Ekahau analyze channel overlapping, spectral congestion, co-channel interference, and signal-to-noise ratio (SNR) across multi-floor facilities.

SUPPORTED HARDWARE

Monitor-Mode Chipsets

Software requires wireless chipsets supporting native packet injection. Standard cards include the Atheros AR9271, MediaTek MT7612U, and Realtek RTL8812AU, deployed with external SMA connectors for directional antenna integration.

TOOL	PRIMARY FUNCTION	KEY ATTRIBUTES
Kismet	Passive RF Sniffer & IDS	Passive channel hopping, GPS logging, detects rogue APs and wireless IDS alerts.
WiFi Analyzer	Mobile Signal Meter	Android handheld survey app for plotting real-time channel overlap and RSSI heatmaps.

Wireless Hacking Tools: cracking and attack suites

Attacking wireless infrastructure involves coordinated utility suites that deauthenticate clients, capture key exchanges, and execute high-speed hash recovery.

SUITE 01

The Aircrack-ng Framework

The definitive 802.11 exploitation toolkit containing specialized CLI binaries:

- **airmon-ng:** Enables monitor mode on raw wireless interfaces, killing interfering network processes.
- **airodump-ng:** Captures raw 802.11 frames, displaying APs, BSSIDs, encryption, channels, and associated stations while writing IVs and handshakes to disk.
- **aireplay-ng:** Generates and injects synthetic traffic, including deauthentication frames, fake associations, and ARP replays.
- **aircrack-ng:** Recovers 802.11 keys via statistical FMS/PTW cracking on WEP and dictionary attacks against WPA/WPA2 handshakes.

SUITE 02

Automated & Rogue AP Frameworks

Advanced tooling for automated cracking and social engineering workflows:

- **Wifite:** Automated script that audits surrounding networks, sequentially executing PMKID capture, WPS attacks, and handshake deauthentication.
- **Reaver & Bully:** Automate brute-force attacks against WPS PIN architecture and execute Pixie Dust offline math attacks.
- **Wifiphisher & Fluxion:** Instantiates targeted evil twin APs while running jammer deauth loops, serving credential-harvesting phishing portals to lured victims.
- **hashcat (Mode 22000):** High-performance GPU cracker optimizing WPA-PBKDF2-PMKID and EAPoL handshake evaluation.

> ### Modern PMKID Attack Vector (WPA/WPA2 Clientless)
>
> Discovered by atom (hashcat), attackers can retrieve the PMKID directly from the First EAPoL Message of the AP without waiting for a client to associate. Transmitting a single association request to a vulnerable AP recovers the PMKID hash, allowing completely clientless offline dictionary attacks.

Bluetooth Hacking: how it works and what breaks

Bluetooth operates in the 2.4 GHz ISM band using Frequency Hopping Spread Spectrum (FHSS) across 79 channels (1 MHz each) in Classic, and 40 channels (2 MHz each) in BLE.

01 Architecture: Piconets & Scatternets

A Piconet links one master device with up to seven active slave nodes. Multiple piconets overlap to form scatternets. Devices identify via a 48-bit BD_ADDR hardware address.

02 Bluejacking

Sending unsolicited vCard or text messages to discoverable Bluetooth devices using the OBEX (Object Exchange) push profile. Irritating but non-invasive; no data is extracted.

03 Bluesnarfing & Bluebugging

Bluesnarfing exploits OBEX vulnerabilities to covertly exfiltrate contacts, call logs, and SMS messages without pairing. Bluebugging creates a serial connection to issue AT modem commands, initiating unauthorized calls and eavesdropping.

04 BlueBorne & Denial of Service

BlueBorne encompasses remote code execution vulnerabilities across Android, iOS, and Linux Bluetooth network encapsulation stacks without pairing. Bluesmacking floods targets with oversized L2CAP ping packets, crashing the host stack.

BLUETOOTH TOOLING / AUDIT HARDWARE

Recon Tools

Btscanner / BlueScanner / Redfang

SDR Sniffer

Ubertooth One (Host-driven sniffer)

Protocol Layers

HCI / L2CAP / RFCOMM / SDP



Hardware packet sniffer used for non-promiscuous Bluetooth monitoring

Countermeasures: hardening Wi-Fi and Bluetooth

Defending wireless boundaries requires deprecating legacy ciphers, mandating mutual certificate authentication, and eliminating dependence on security through obscurity.

CONTROL 01

Encryption Protocol Enforcement

Mandate WPA3-Enterprise or WPA2-Enterprise with AES-CCMP. Explicitly disable legacy WEP, WPA-TKIP, and Wi-Fi Protected Setup (WPS) at the controller level. Prohibit pre-shared keys (PSK) in corporate environments to prevent handshake cracking.

CONTROL 02

Protected Management Frames

Enable IEEE 802.11w Protected Management Frames (PMF) on all access points. PMF cryptographically signs deauthentication and disassociation frames using BIP (Broadcast Integrity Protocol), completely neutralizing deauth-flooding attacks.

CONTROL 03

Reject False Security Controls

Discard SSID hiding and MAC filtering as defensive controls. Hidden SSIDs are trivial to uncloak in real time, and static MAC access control lists are instantly bypassed via Layer 2 MAC address spoofing.

CONTROL 04

Network Segmentation & Bluetooth

Place guest wireless on strictly isolated VLANs with client-to-client isolation enabled. For Bluetooth: set devices permanently to Non-Discoverable mode, enforce Secure Connections Pairing, and patch OS Bluetooth driver stacks promptly.

DOMAIN	VULNERABLE CONFIGURATION	HARDENED BASELINE
Authentication	WPA2-PSK (Shared Passphrase)	WPA3-Enterprise (802.1X EAP-TLS with Mutual Certificates)
Management	Unprotected Management Frames	IEEE 802.11w Mandatory (PMF Enabled)

Wireless Security Tools

Enterprise wireless defense depends on continuous radio frequency monitoring, automated rogue containment, and certificate-backed identity infrastructure.

DEFENSIVE ARCHITECTURE

WIPS / WIDS Sensors

Dedicated Wireless Intrusion Prevention Systems (such as Cisco CleanAir, Aruba RFProtect, and AirTight/Arista WIPS) deploy overlay sensors to detect and mitigate threats in real time:

- **Rogue AP Containment:** Transmits targeted deauthentication frames to rogue BSSIDs and associated stations while alerting administrators.
- **Attack Signature Detection:** Flags active deauth floods, evil twin impersonations, association table exhaustion, and RF jamming signatures.
- **Location Tracking:** Triangulates unauthorized devices across RF sensor grids using Received Signal Strength Indicators.

AUDIT & IDENTITY

Auditing Suites & 802.1X Infrastructure

Proactive assessment tools and centralized authentication engines validate defensive posture:

- **Defensive Auditing:** Security teams leverage Aircrack-ng and Kismet to inspect corporate boundaries for unauthorized beacons, weak ciphers, and leaking SSIDs.
- **RADIUS Engines:** FreeRADIUS and Cisco ISE validate EAP-TLS supplicants against Active Directory, issuing dynamic VLAN assignments per user role.
- **Spectrum Analyzers:** Dedicated hardware monitors RF noise, identifying non-802.11 interference from microwave ovens, radar, and jamming hardware.

CATEGORY	PRODUCT / ENGINE	DEFENSIVE CAPABILITY
Enterprise WIPS	Aruba AirWave / Cisco Prime	Continuous RF scanning, automated rogue AP suppression, and physical asset triangulation.
Access Control	FreeRADIUS / Cisco ISE	Centralized 802.1X EAP-TLS authentication, certificate validation, and dynamic ACL enforcement.
RF Diagnostics	MetaGeek Wi-Spy / Chanalyzer	Raw physical spectrum monitoring to identify interference and RF jamming activity.

SUMMARY & CERTIFICATION CHECKLIST

Key Takeaways and Exam Review

Core concepts, attack sequences, and protocol weaknesses essential for certification candidates and practicing security engineers.

01

Methodology Sequence

Remember the order: Discover & Survey → Traffic Analysis → Launch Attack → Crack Key → Pivot Internally.

02

WEP vs. WPA3

WEP fails via 24-bit IV reuse and CRC-32. WPA3 eliminates offline dictionary attacks using Dragonfly SAE.

03

802.11w Protection

Protected Management Frames cryptographically sign management packets, terminating deauth attack vectors.

CIA PILLAR	ATTACK VECTOR	DEFENSIVE MITIGATION
Confidentiality	Evil Twin / Eavesdropping	WPA3-Enterprise, 802.1X EAP-TLS, full payload VPN encapsulation.
Integrity	Frame Injection / Replay	AES-CCMP authenticated encryption with dynamic message integrity codes.
Availability	Deauth Flooding / Jamming	Enable 802.11w (PMF); deploy physical WIPS sensors for rogue AP containment.
Access Control	Rogue AP / MAC Spoofing	802.1X port security on wired switches, rogue AP auto-suppression, 802.1X auth.